

Lab 5: Sitting in the Middle — Web Application Testing with Burp Suite

Session 5 — Intercepting and Manipulating Web Traffic

Course: Hands-On Ethical Hacking and Network Defense, 4e — Module 1 companion lab **Estimated time:** 100–120 minutes **Prerequisite:** Labs 1–4 completed. OWASP BWA is running and reachable on your host-only network (confirmed in Lab 2, Part D). **Based on:** Module 1’s “What Interception Actually Looks Like” and “Sitting in the Middle: An Intercepting Proxy.”

1. Learning Objectives

By the end of this session you will be able to:

- Configure Burp Suite as an intercepting proxy between a browser and a target web application
- Capture, read, and modify an HTTP request before it reaches the server
- Use Burp’s Proxy history and Repeater to build a small map of an application’s endpoints
- Connect at least two observations to specific categories in the OWASP Top Ten
- Explain, in your own words, why a proxy is “the active cousin” of the passive sniffer from Lab 2

2. ⚠ Scope Reminder

Everything below runs against your own OWASP BWA VM, on the host-only network from Lab 1. A proxy and a packet sniffer both depend on sitting between two ends of a connection — that position needs to be authorized whether you’re reading traffic (Lab 2) or actively rewriting it (this lab). Nothing here targets a real website.

3. What You’ll Need

- Kali with Burp Suite Community Edition (pre-installed) and a browser (Firefox)
- OWASP BWA running and reachable — confirm its address before starting
- A restored `baseline-pre-attack` snapshot of OWASP BWA

4. Procedure

Part A — Launch OWASP BWA and Pick a Target Application

1. From a browser on Kali, browse to your OWASP BWA VM’s IP address. This lands on a menu of separate vulnerable applications bundled on the same VM (titles vary by build — look for a classic login-driven app such as DVWA, WebGoat, or Mutillidae).
2. Pick **one** application with a visible login form. Note its name and full URL path.
3. Do not log in yet.

Part B — Configure Burp as Your Proxy

1. Launch Burp Suite (Community Edition), start a new temporary project, and open the **Proxy** tab.
2. Confirm the proxy listener is running on `127.0.0.1:8080` (**Proxy → Options/Settings**).
3. In Firefox, go to network/proxy settings and set a manual HTTP proxy: `127.0.0.1`, port `8080`. Apply it to all protocols.
4. Load a plain page through the proxied browser and confirm traffic appears in Burp’s **Proxy → HTTP history**. If nothing appears, revisit your proxy settings before continuing.

Part C — Freeze a Login Request in Transit

1. In Burp’s Proxy tab, turn **Intercept** on.
2. In the browser, go to your chosen application’s login form and submit **any** dummy username/password.
3. Back in Burp, find the frozen request. Before forwarding it, identify and record:
 - The HTTP method and full path
 - Every header sent, including the session cookie if one is present
 - The request body — where exactly do the username and password sit?
4. Forward the request once you’ve recorded all four.

Part D — Change It Before It Arrives

1. Repeat Part C, but this time, before forwarding, edit one value in the request body (for example, change the

username to something else, or flip a hidden field's value if the form has one).

2. Forward the edited request and observe the application's response. Record what changed.
3. Turn **Intercept** off once you're done experimenting, so normal browsing resumes.

Part E — Build an Endpoint Map from Proxy History

1. Click around the application for two or three minutes — browse a few pages, submit a search box, view an item.
2. Open **Proxy → HTTP history** and build a table of **at least five** distinct requests: method, path, and one notable parameter each.
3. Sort the table by how sensitive each parameter looks (a `price` or `id` field is more interesting than a static asset request).

Part F — Send One Request to Repeater

1. Right-click a request that includes a numeric or ID-like parameter and choose **Send to Repeater**.
2. In Repeater, change that parameter's value (for example, increment an ID) and resend.
3. Compare the response to the original. Record whether the application returned different data, an error, or no visible change.

Part G — Map Findings to the OWASP Top Ten

For at least **two** observations from Parts C–F, name the OWASP Top Ten category that best fits (for example: credentials traveling in plaintext over HTTP maps to a cryptographic-failures category; a parameter that changes what data comes back without any permission check maps to a broken-access-control category). One sentence of justification each.

Part H — Clean Up

1. Turn Firefox's proxy setting back to "No proxy" (or "Use system settings") so normal browsing outside this lab isn't routed through Burp.
2. Close the Burp project without saving, unless your instructor wants it submitted.
3. Restore OWASP BWA's `baseline-pre-attack` snapshot.

5. What to Submit

1. Your Part C recording (method, headers, cookie, body location of credentials)
2. A screenshot of your Part D edited request and the application's response
3. Your Part E endpoint table (5+ rows)
4. Your Part F before/after Repeater comparison
5. Your two Part G OWASP Top Ten mappings with justification

Reflection (3–4 sentences): Module 1 calls Wireshark and Burp "the same lesson, different tool" — both depend on position, and both need that position authorized. What can Burp do that Wireshark, used purely as a passive sniffer, cannot? What can Wireshark see that Burp, sitting only in the browser's path, would miss entirely?

6. Troubleshooting

Symptom	Likely cause / fix
No traffic appears in Burp's HTTP history	Firefox's proxy settings didn't save, or Burp's listener isn't running — recheck both, in that order
Intercept never catches anything	Confirm "Intercept is on" is actually toggled, not just the tab open
The application won't load at all through the proxy	Confirm you're browsing to OWASP BWA's host-only address, not <code>localhost</code> or an external site

Next session: Lab 6 — The Letter You Carry (scoping and authorization). Bring a notebook — this one is mostly paperwork, and it matters just as much as the exploit.